

Security+ 2.4 · Cryptographic Attacks

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4** —
Cryptographic Attacks (9:31) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Cryptographic attacks target the algorithms and protocols that protect data. A downgrade attack forces two parties to negotiate a weaker protocol or cipher suite (e.g., SSL stripping downgrades HTTPS to HTTP). Hash collisions occur when two different inputs produce the same hash value; MD5 and SHA-1 are deprecated because practical collisions exist. Brute-force attacks exhaustively try keys or passwords. Defenses include HSTS (which instructs browsers to never accept HTTP downgrades), patching cryptographic libraries, and using current algorithms such as TLS 1.3.

High-Yield Core Concepts Tested on Exam

- Downgrade attack: forces use of a weaker protocol version (e.g., SSL stripping from HTTPS to HTTP).
- HSTS: browser remembers a site is HTTPS-only, mitigating SSL stripping and downgrade attacks.
- Hash collision: two different inputs produce the same hash; MD5 and SHA-1 are deprecated due to practical collisions.
- Brute-force key attack: exhaustively tries all possible keys; feasibility depends on key length and algorithm strength.
- Defense: patch cryptographic libraries, enforce TLS 1.3, and enable HSTS.

Exam Tips & Classic Scenarios

- 'forces a connection to a weaker protocol' = downgrade attack.
- 'prevents downgrade to HTTP' = HSTS (HTTP Strict Transport Security).
- 'two different messages with the same hash' = collision (MD5/SHA-1 deprecated).

Typical Exam Scenario: An attacker intercepts the initial request and returns an HTTP response without TLS, forcing the client to communicate in cleartext. This is SSL stripping, a downgrade attack. The defense is HSTS, which ensures the browser only connects via HTTPS.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Cryptographic Attacks)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. The correct way to STORE user passwords:

- A)** Hash with salt (e.g., bcrypt)
- B)** Reversible AES encryption
- C)** Plaintext protected by firewall
- D)** Base64

2. A characteristic of HASH (unlike encryption) is that it:

- A)** Can be reversed with the key
- B)** Is one-way (not reversible)
- C)** Always shortens the text by half
- D)** Requires a key pair

3. Corporate scenario (Cryptographic Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Downgrade: convinces to use a WEAK version (SSL stripping).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Downgrade: convinces to use a WEAK version (SSL stripping).
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Cryptographic Attacks): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 2.4) exam, an analyst evaluates the following technical requirement: 'HSTS: the browser REMEMBERS that the site is HTTPS-only — mitigates SSL strip'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: HSTS: the browser REMEMBERS that the site is HTTPS-only — mitigates SSL strip...
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Cryptographic Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Collision MD5/SHA-1: two texts, same hash — deprecated'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Collision MD5/SHA-1: two texts, same hash — deprecated...
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Cryptographic Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: "forces a connection to a weaker protocol" = downgrade attack'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'forces a connection to a weaker protocol' = downgrade attack...
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Cryptographic Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'prevents downgrade to HTTP' = HSTS. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'prevents downgrade to HTTP' = HSTS...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Cryptographic Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: 'attacker intercepts the first request and returns an HTTP response (without TLS)' = SSL stripping; defense: HSTS.'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'attacker intercepts the first request and returns an HTTP response...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Cryptographic Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Downgrade: convinces to use WEAK version (SSL stripping)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Downgrade: convinces to use WEAK version (SSL stripping)...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Cryptographic Attacks): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'HSTS: the browser REMEMBERS that the site is HTTPS-only — mitigates SSL strip'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: HSTS: the browser REMEMBERS that the site is HTTPS-only — mitigates SSL strip...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Hash with salt (e.g., bcrypt).

✓ **Why it is correct:** Secure storage of user passwords requires the use of slow cryptographic hash functions resistant to brute-force attacks, such as bcrypt, scrypt, or Argon2, combined with a unique random salt per user. The salt prevents precomputed table attacks (rainbow tables) and ensures that identical passwords produce different hashes. Functions like bcrypt are designed to be computationally expensive, adjustable by cost factor, making dictionary and offline brute-force attacks difficult. The hash is one-way, so even if the database is compromised, the attacker does not directly obtain the original password, only the hash, which must be cracked individually.

✗ **Why the others are wrong:**

- *Reversible AES encryption:* AES is a reversible symmetric cipher: with the correct key, the ciphertext can be decrypted back to plaintext. If passwords are stored encrypted with AES, anyone who obtains the encryption key (e.g., through compromise of the application server or database) can recover all original passwords. This violates the principle that not even system administrators should know user passwords. Additionally, AES key management adds unnecessary complexity and risk for data that never needs to be recovered in plaintext.
- *Plaintext protected by firewall:* Storing passwords in plaintext means they are readable in the database or configuration file. A firewall protects against unauthorized network access but does not prevent an attacker who exploits an application vulnerability, a malicious insider, or an administrator with database access from directly reading the passwords. Defense in depth requires that sensitive data be protected at rest, regardless of perimeter controls. A firewall is a network control, not a credential storage control.
- *Base64:* Base64 is a reversible encoding without a key, often used to represent binary data in text. It offers no confidentiality: anyone can decode a Base64 string instantly. Storing passwords in Base64 is functionally equivalent to storing them in plaintext, just with an obfuscated appearance. There is no salt, no computational cost, and no resistance to attacks. It is a completely inadequate practice for credential protection.

2) B — Is one-way (not reversible).

✓ **Why it is correct:** A fundamental characteristic of cryptographic hash functions is that they are one-way, i.e., not reversible. This means that from the hash, it is not possible to recover the original message. This property is known as pre-image resistance. Unlike encryption, which is reversible with the correct key, hashing is designed to be irreversible. CompTIA Security+ highlights that hash functions like SHA-256 are used for integrity and password storage (with salt), precisely because they cannot be reversed. The option 'Is one-way (not reversible)' correctly describes this essential characteristic.

✗ **Why the others are wrong:**

- *Can be reversed with the key:* This is a characteristic of symmetric or asymmetric encryption, not hash functions. In encryption, reversal is possible with the appropriate key (symmetric) or with the private key (asymmetric). Hash functions have no key and are not designed for reversal. Therefore, this statement is incorrect for hash. CompTIA Security+ emphasizes that hash is one-way and does not use keys, unlike cipher.
- *Always shortens the text by half:* Hash functions produce a fixed-size output regardless of input size. For example, SHA-256 always generates 256 bits (32 bytes). There is no 'shorten by half' rule; the digest size is constant and defined by the algorithm. Moreover, the hash function is not simple compression; it must be resistant to collisions and pre-image. This statement is technically false and does not describe a hash property.

- *Requires a key pair*: Hash functions do not use keys. They are public and deterministic algorithms that map input data to a digest. The use of a key pair is characteristic of asymmetric encryption (such as RSA or ECC), not hash. Although hashes can be used together with keys in HMAC, the hash function itself does not require keys. Therefore, this option is incorrect.

3) B — Implement the corresponding solution: Downgrade: convinces to use a WEAK version (SSL stripping)..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Cryptographic Attacks): Downgrade: convinces to use a WEAK version (SSL stripping). A downgrade attack forces a system to abandon a secure protocol version or cipher suite in favor of a weaker one. SSL stripping is a specific man-in-the-middle technique that downgrades HTTPS to HTTP. The correct mitigation is to enforce strong protocol versions and cipher suites, disable weak ones, and implement HSTS.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) C — Implement the corresponding solution: HSTS: the browser REMEMBERS that the site is HTTPS-only — mitigates SSL strip....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Cryptographic Attacks): HSTS: the browser REMEMBERS that the site is HTTPS-only — mitigates SSL strip. HSTS forces the browser to use HTTPS for all future connections to the site, preventing SSL stripping attacks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) C — Implement the corresponding solution: Collision MD5/SOA-1: two texts, same hash — deprecated....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Cryptographic Attacks): Collision MD5/SOA-1: two texts, same hash — deprecated. MD5 and SHA-1 are considered cryptographically broken because practical collision attacks have been demonstrated. A collision occurs when two different inputs produce the same hash value, undermining integrity and digital signature trust. The correct action is to deprecate these algorithms and migrate to collision-resistant hash functions such as SHA-256 or SHA-3.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: 'forces a connection to a weaker protocol' = downgrade attack....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Cryptographic Attacks): 'forces a connection to a weaker protocol' = downgrade attack.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: 'prevents downgrade to HTTP' = HSTS....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Cryptographic Attacks): 'prevents downgrade to HTTP' = HSTS. HTTP Strict Transport Security (HSTS) is a security policy mechanism that forces browsers to interact with a site only over HTTPS, preventing protocol downgrade attacks and cookie hijacking.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: Scenario: 'attacker intercepts the first request and returns an HTTP response....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Cryptographic Attacks): Scenario: 'attacker intercepts the first request and returns an HTTP response (without TLS)' = SSL stripping; defense: HSTS..

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: Downgrade: convinces to use WEAK version (SSL stripping)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Cryptographic Attacks): Downgrade: convinces to use WEAK version (SSL stripping). A downgrade attack forces a system to use a weaker encryption protocol or algorithm, such as SSL instead of TLS, often through SSL stripping. This matches the description.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: HSTS: the browser REMEMBERS that the site is HTTPS-only — mitigates SSL strip....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Cryptographic Attacks): HSTS: the browser REMEMBERS that the site is HTTPS-only — mitigates SSL strip. HTTP Strict Transport Security (HSTS) is a web security policy mechanism that forces browsers to interact with a site only over HTTPS, preventing protocol downgrade attacks and cookie hijacking.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

